

EtherRAT On-Chain C2 — Intelligence Assessment

A DPRK/Iran Shared-Builder EtherHiding Resolver Family, with Wire-Level C2 Confirmation

Classification	TLP:CLEAR
Analytic standard	ICD-203 (Analytic Standards) · ICD-206 (sourcing)
Author	Yanky Wilson — independent CTI researcher (github.com/yankywilson)
As of	15 June 2026
Reporting window	4 December 2025 – 14 June 2026
Methodology	Passive OSINT, on-chain-first, air-gapped
Companion repo	Iranian cluster: github.com/yankywilson/muddywater-etherhiding-resolver-family

Scope & sourcing note. This assessment is built primarily from original on-chain analysis (Ethereum mainnet, read-only block explorers) and third-party internet-scan data (Shodan, Censys, crt.sh), validated against vendor reporting from Sysdig, eSentire, The DFIR Report, Kaspersky, and Google/Mandiant (GTIG). Findings are tagged **NOVEL** (first-published here; absent from external reporting), **CORROBORATED** (independently confirmed across ≥2 sources in this investigation), **PUBLISHED** (already in vendor reporting; reproduced for completeness), or **EXCLUDED** (investigated and ruled out — recorded as a finding, not an omission). Confidence levels follow ICD-203. Estimative likelihood uses the standard lexicon: *almost no chance* (1–5%), *unlikely* (20–45%), *roughly even* (45–55%), *likely* (55–80%), *highly likely* (80–95%), *almost certain* (95–99%). Single-vendor attribution is capped at MODERATE. **No contact was made with live C2 infrastructure**; all host data derives from third-party scanners.

1. Executive Summary

EtherHiding — storing a malware command-and-control (C2) address inside a public blockchain smart contract so it can be retrieved at runtime without DNS — has moved from a single-actor novelty into a **shared capability** used by at least two distinct nation-state-aligned clusters. Public reporting documents the technique (Google/Mandiant first attributed DPRK adoption; Sysdig named the EtherRAT implant; eSentire tied it to the Iranian-hosted Tsundere botnet), but treats each actor's on-chain footprint as a small number of individual contracts.

On-chain enumeration in this investigation establishes three things that public reporting does not.

First, the EtherRAT C2 resolver is not a handful of unrelated contracts but a **defined family** compiled from a single source. Four contracts are documented here; three were named by vendors, and a **fourth (0x40A7d723...fBc4f85) appears in no public report** — it surfaced by pivoting through the funding graph rather than through malware samples. Three of the four are byte-for-byte identical, sharing an identical Solidity compiler-metadata IPFS hash; the fourth is a minor fork usable as its own clustering fingerprint.

Second, the DPRK EtherRAT family and the Iranian Tsundere family **share a builder at the code level**. They emit the identical `StringChanged` event topic (`0x3ca6280d...`) and, for the identical-bytecode set, the same compiler-metadata hash. This corroborates *on-chain* what eSentire reported only as source-code overlap, and is consistent with a shared Malware-as-a-Service (MaaS) builder rather than independent re-implementation.

Third, one decoded C2 host — `91.215.85.42` — was confirmed as a **live EtherRAT panel** by three independent methods: the on-chain write, a Shodan banner carrying the EtherRAT-specific `X-Bot-Server` header, and a behavioral packet capture showing a detonated sample beaconing to it with no preceding DNS lookup.

Critically, the shared builder does **not** extend to shared operation. Operator and funding wallets are disjoint across the two clusters; the DPRK funding chain was walked to termination at a no-KYC instant-swap exchange (SideShift) with no observed link to any Iranian operator. The defensible conclusion is a **shared toolkit/builder lineage with independent operation and financing** — not a single actor, and not a confirmed operational partnership.

The investigation also produced a disciplined **negative**: a second decoded host, `173.249.8.102`, hosts a live but entirely unrelated Moroccan email-marketing/phishing operation. It is a decoy or recycled co-tenant IP, not actor C2. This is retained deliberately as a methodological finding (Section 9): **resolver calldata contains entries that are not all live actor infrastructure, and every decoded indicator requires independent validation before it is called C2.**

2. Key Judgments

KJ-1. We assess with HIGH CONFIDENCE that the EtherRAT EtherHiding C2 resolver constitutes a contract family compiled from a single source, comprising at least four contracts on Ethereum mainnet. Three are named in vendor reporting (Sysdig, eSentire, The DFIR Report); the fourth — `0x40A7d723F5Df6c88464bC95DBf7D96573fBc4f85` — is first published here. Contracts #1, #2, and #4 are byte-for-byte identical with an identical compiler-metadata IPFS hash (`1de57633...`); all four share the read/write selectors `0x7d434425` / `0x7fcdf666`. *Basis*: direct bytecode comparison; identical metadata hash is dispositive of a shared source-and-compiler build. *Confidence driver*: cryptographic-grade identity, not behavioral similarity.

KJ-2. We assess with HIGH CONFIDENCE that the DPRK-attributed EtherRAT family and the Iranian-hosted Tsundere family share a common builder or codebase. Both emit the identical `StringChanged` topic (`0x3ca6280dac32fee85e9d3d81188d59eed7e4966e5b3df13a910924cf6ade2d47`); the identical-bytecode set shares the compiler-metadata hash. This corroborates, on-chain, eSentire's reported EtherRAT ↔ Tsundere source-code overlap. *Alternative considered and assessed unlikely*: coincidental selection of an identical event signature and compiler fingerprint by two independent developers — implausible given the metadata-hash match. *Boundary*: this is a **tooling** link, not an operational one (see KJ-4).

KJ-3. We assess with HIGH CONFIDENCE that `91.215.85.42` is a live EtherRAT command-and-control host. It is written into contract #1 on-chain, presents the EtherRAT `X-Bot-Server` CORS header on its `:3000` panel (Shodan, last seen 2026-06-14), and was observed receiving a live beacon from a detonated sample in a behavioral PCAP, returning a matching server `ETag`. Ports `3000` (EtherRAT) and `3001` (Tsundere WebSocket C2) are co-hosted. *Confidence driver*: three independent observation channels (chain, scan, wire) agree.

KJ-4. We assess with MODERATE CONFIDENCE that the DPRK and Iranian operations are operated and financed separately despite the shared builder. Operator and deployer wallets are disjoint; the DPRK funding chain terminates at SideShift with no link to any Iranian operator wallet. *Why only MODERATE*: on-chain disjointness rules out shared *wallets*, but cannot exclude off-chain coordination, a shared upstream the chain does not reach, or operators who deliberately compartmentalize funding. The clusters share funding *typology* (no-KYC swaps), which is non-discriminating and is **not** treated as a link.

KJ-5. We assess with HIGH CONFIDENCE (methodological) that resolver calldata contains decoy or recycled co-tenant entries that are not live actor C2. Demonstrated by `173.249.8.102` (hosting an unrelated live Moroccan phishing operation) and by the prior-tenant phishing history on `91.215.85.42`'s recycled bulletproof IP.

Implication for defenders: decoded EtherHiding indicators must be independently validated; bulk-ingesting resolver calldata as C2 will generate false positives and false attributions.

Attribution caveats carried throughout. EtherRAT's attribution to DPRK (UNC5342 / "Contagious Interview" nexus) rests substantially on Sysdig and is carried at **MODERATE** (single principal vendor, self-hedged). Tsundere's attribution to a Russian-speaking actor ("koneko") rests on Kaspersky plus Outpost24 and is carried at **MODERATE–HIGH**. This assessment does **not** assert the two clusters are the same actor.

3. Background — EtherHiding and the EtherRAT / Tsundere ecosystem

EtherHiding (ATT&CK T1102.001, Web Service: Dead Drop Resolver). The operator deploys a smart contract whose storage holds the current C2 address as a string. The implant reads it at runtime by issuing an `eth_call` to a public Ethereum RPC node — a free, read-only query that costs no gas and emits no transaction. To rotate C2, the operator sends a single `setString` transaction. The defensive consequence is significant: the C2 address never appears in DNS, the resolver contract cannot be taken down by a registrar or hosting provider, and the only reliably durable artifacts are (a) the contract/topic on-chain and (b) the implant's server-side fingerprint.

EtherRAT. A Node.js implant first detailed publicly by Sysdig (December 2025), assessed as DPRK-nexus and observed in intrusions chaining the React2Shell vector (CVE-2025-55182) and malicious-MSI/Sysinternals-spoofing delivery. It reads C2 via the resolver getter and beacons over HTTP to a panel on port `3000` ; its responses carry the distinctive `X-Bot-Server` CORS header.

Tsundere. A separate Node.js botnet documented by Kaspersky, attributed to a Russian-speaking operator using the handle "koneko," with CIS-geofencing characteristics consistent with a MaaS sold within a Russian-speaking ecosystem. Its C2 listener runs as a WebSocket service on port `3001` .

The convergence. eSentire (March 2026) reported that Iranian operator infrastructure was hosting Tsundere via EtherHiding and noted source-code overlap between EtherRAT and Tsundere. The DFIR Report subsequently documented a further resolver contract. The picture that emerges — and that this assessment sharpens — is of a **common EtherHiding resolver kit** adopted across DPRK and Iranian operations, with Russian-speaking MaaS as the probable origin of the shared tooling.

4. The resolver family

4.1 Contract mechanics

Each resolver is a minimal `string` -storage contract exposing two functions:

Selector	Function	Role
<code>0x7d434425</code>	<code>getString(address)</code>	Read. View call; returns the stored C2 string for a given operator address. No transaction, no gas, no DNS.
<code>0x7fcaf666</code>	<code>setString(string)</code>	Write. Stores a new C2 string and emits <code>StringChanged</code> . The C2 value travels in cleartext in the transaction calldata.

Every write emits `StringChanged(address indexed account, string newString)` , whose topic-0 — `0x3ca280dac32fee85e9d3d81188d59eed7e4966e5b3df13a910924cf6ade2d47` — is the durable, IP-rotation-proof family

anchor.

4.2 The four contracts

#	Contract	Operator	setString writes	Window	Source
1	0x22f96D61cF118efaBC7C5bF3384734FaD2f6eaD4	0xE941A9b2...5951c4C8D	9	5–8 Dec 2025	Sysdig — PUBLISHED
2	0xe26c57B7fA8de030238b0a71b3d063397aC127D3	0x8D7e3Cc5...A4d398C12	25	20 Jan – 18 May 2026	eSentire — PUBLISHED
3	0xDf0B529043Ef7a2BB9111bAd26de624a326baCf9	0x5953f27F...583Dd2E4e	25	24 Apr – 5 May 2026	DFIR Report — PUBLISHED
4	0x40A7d723F5Df6c88464bC95DBf7D96573fBc4f85	0x14afdDD6...1eCb1C708	1	4 Dec 2025	NOVEL

4.3 The build fingerprint (Family A — #1, #2, #4)

These three are **byte-for-byte identical**:

Fingerprint	Value
Read / write selectors	0x7d434425 / 0x7fcaf666
StringChanged topic-0	0x3ca6280d...ade2d47
Solc metadata IPFS hash	1de57633fefe5e5685ff0dc91b16c628ac4b2544e90be126d02cda08fa28ce11
Compiler	solc 0.8.30 (0x081e in the metadata trailer)

The **IPFS metadata-hash match** is the load-bearing evidence: it means the same source file, the same compiler version, and the same compiler settings produced all three contracts. This is redeployment of one build artifact, not "similar-looking code."

4.4 The variant (Family B — #3)

Contract #3 is a fork of the same kit: it adds two constant-returning getters (**0x62b57aeb** , **0x62bf2985**), emits a different **StringChanged** topic (**0x3c520374...**), and carries a different metadata hash (**264fe4a1...**). The two added constant selectors are themselves a usable fingerprint for hunting further Family B variants.

Decode status. Contract #3 carries 25 writes spanning Apr–May 2026 — the newest and most active infrastructure in the family — and is **pending calldata decode** at publication. Its hosts will be appended to **I0Cs/c2_hosts.csv** . On current evidence it is the contract most likely to contain additional currently-live C2.

5. On-chain methodology — how the family (and the novel contract) surfaced

The enumeration did not start from malware samples. It started from the published contracts and pivoted outward on two axes:

1. **Topic/bytecode clustering.** Confirming family membership for any candidate contract is mechanical: pull the runtime bytecode, confirm the `7d434425 / 7fcdf666` selectors, the `3ca6280d` topic, and the `1de57633...` IPFS trailer. Any contract matching all four is Family A.
1. **Wallet pivoting.** Each operator and deployer wallet's transaction history exposes (a) every contract that wallet deployed and (b) the wallet that funded it. Walking *up* the funding chain from operator #1 surfaced the funder `0x14afdDD6` — and that wallet had itself **deployed a contract** (`0x40A7d723...`, contract #4) and written `api-gateway-prod.com` to it 18 minutes before funding the operator. Contract #4 appears in no vendor report; it was reachable only through the funding graph.

This is the core methodological contribution: **the resolver family is best enumerated by pivoting on wallets, not by collecting samples.** Sample-driven discovery finds contracts that appear in captured payloads; wallet-driven discovery finds the contracts the operators deployed but had not yet (or only briefly) put into rotation.

6. Live C2 confirmation — `91.215.85.42`

Decoded from contract #1's calldata as `http://91.215.85.42:3000`. Confirmed live by three independent channels:

(a) **On-chain.** Written via `setString` on contract #1 by operator `0xE941A9b2...`, December 2025.

(b) **Internet-scan (Shodan, last seen 2026-06-14).** Open ports `22`, `3000`, `3001`, `5432`, `6379`. The `:3000` HTTP response carries the EtherRAT server fingerprint:

```
HTTP/1.1 404 Not Found
Access-Control-Allow-Headers: Content-Type, Authorization, X-Bot-Server
ETag: W/"9-0gXLIngzMqISxa6S1zx3F4wtLyg"
```

`X-Bot-Server` is the EtherRAT-specific CORS allow-header documented by Sysdig. Port `3001` is the Tsundere WebSocket C2 listener; `5432` (PostgreSQL) and `6379` (Redis) are the panel's data backends, both exposed. Hosting: **PROSPERO OOO, AS200593, St. Petersburg, RU** — a provider with a long bulletproof-hosting reputation.

(c) **Wire-level (behavioral PCAP).** A detonated sample (victim host `10.127.0.206`) made `91.215.85.42` the single most-contacted external host in the capture (268 packets, ports `80` and `3000`). The server returned the same `X-Bot-Server` header and the **identical ETag** observed by Shodan — confirming a stable server build across the two observation points. Decisively, the implant reached the C2 **by direct IP with no preceding DNS query**; all DNS in the capture was benign Microsoft/Google OS telemetry. This is the EtherHiding model working exactly as designed: the C2 address comes from the blockchain, so it never appears in DNS.

The co-hosting of EtherRAT (`:3000`) and Tsundere (`:3001`) on a single server is the **infrastructure-level analogue** of the code overlap reported by eSentire, and is consistent with shared tooling operated from a common panel.

Calibration. Passive DNS for `91.215.85.42` (2023–2024) is dominated by Japanese/Turkish payment-phishing and fake-news domains. These are **prior tenants of a recycled bulletproof IP**, predate EtherRAT use, and are **EXCLUDED**. The IP is treated as live EtherRAT C2 *now*; the historical domains are not attributed to this actor.

7. The `api-gateway-prod.com` campaign window

Decoded from contract #4. The certificate transparency record yields an unusually clean, bounded campaign lifecycle.

Signal	Value
Resolution (point-in-time)	<code>193.200.17.66</code> (BlueVPS, AS62005, Warsaw PL; MikroTik tenant)
TLS certs ever issued	2 — the SCT pre-cert + leaf pair, both 2025-11-29
Renewals	none
Subdomains	none ever issued
Validity expiry	2026-02-27
On-chain write	2025-12-04
Cert SHA-256	<code>720db1bac2a7a9b682ca84e7a6b897d994bd05d9eb0956c73059d8639d4b17a5</code>

The lifecycle reads: **provisioned 29 Nov** → **weaponized 4 Dec** → **abandoned ~27 Feb**. The current `193.200.17.66` resolution sits on a MikroTik device and is treated as recycled and point-in-time. The **durable** indicators are the domain and the certificate hash; the IP is not. The generic-SaaS naming (`api-gateway-prod`) is camouflage — a name-based sibling hunt returns ~1,250 legitimate results, so pivoting must be done on the certificate hash, not the name.

8. Decoded C2 inventory and validation discipline

Full machine-readable inventory: `IOCs/c2_hosts.csv` . Summary with honest confidence tiers:

Indicator	Contract	Confidence	Verdict
<code>91.215.85.42</code>	#1	HIGH	Live EtherRAT C2 — triple-confirmed
<code>api-gateway-prod.com</code> → <code>193.200.17.66</code>	#4	HIGH	Validated (cert + Censys)
<code>rubysen.com</code> , <code>ager-stp.org</code> , <code>twicegrand.com</code> , <code>aabstone.com</code>	#1	MODERATE	Novel; passive validation pending
<code>173.249.8.102</code>	#1	LOW / EXCLUDED	Decoy or recycled co-tenant (Section 9)
<code>grabify.link/SEFKGU</code>	#1	INFO	IP-logger recon link — not C2
<code>aurineuroth.com</code> + 9 others	#2	PUBLISHED	eSentire-published C2, decode-confirmed

The four MODERATE domains are decoded and real on-chain writes, but are not yet host-validated and are deliberately **not** elevated to HIGH on calldata presence alone — which is precisely the discipline Section 9 justifies.

9. Case study in calibration — the 173.249.8.102 exclusion

173.249.8.102 was decoded from contract #1's calldata, which on a naïve reading would make it actor C2. It is not.

Passive scan and a (logged) page pull show the host running a **live Laravel "ACADEMY — Daily Email Marketing Solution"** application — a bilingual English/Arabic credential-harvesting/spam-kit front end — on **Contabo, AS51167, DE**. Its support block names a separate operator entirely:

Contact	Value
Telegram	t.me/ouzougat
WhatsApp / phone	+212 638 913 011 (+212 = Morocco)
Emails	ouzougat@gmail.com / hotmail / yahoo
Domain	dailyemailmarketingsolution.com

None of the EtherRAT fingerprints are present (no X-Bot-Server, no :3000 / :3001). The application is **current** (live session cookies dated the day of analysis), so the Moroccan spam operator is the **present occupant**, whereas the EtherRAT write was December 2025. The defensible readings are: a **recycled/abused shared VPS**, or a **decoy** entry written to the contract — a pattern The DFIR Report has documented for EtherRAT.

The discipline that follows. None of the ouzougat artifacts, the dailyemailmarketingsolution.com domain, or the stock Contabo TLS/SSH material enters the EtherRAT IOC set (they are recorded in IOCs/excluded.csv). Attributing this Moroccan spam kit to the DPRK/Iran cluster would be exactly the cross-contamination this methodology exists to prevent. The contrast with 91.215.85.42 — one decoded IP triple-confirmed, one decoded IP correctly excluded — is itself evidence that the IOC set is **calibrated rather than inflated** (KJ-5).

10. Funding and financial infrastructure

Full walk: analysis/funding_chain.md. The DPRK chain:

```
SideShift (no-KYC swap, hot wallet 0xcdd37ada...)
  → 0x564Aa2230f9c4944bEf4c9e1aBF8F75cb2e4a23A (Nonce 1, single-use)
  → 0x14afdDD627Fb0e039365554f8bbDB881eCb1C708 (Nonce 2-3, single-use)
    └─ funds operator 0xE941A9b2... (contract #1)
    └─ deploys contract #4 (0x40A7d723...)
```

The intermediaries are fresh, near-drained wallets used once or twice — a per-deployment disposable-wallet pattern. Contract #3's operator (0x5953f27F...) was independently funded via **FixedFloat** and **ChangeNOW**, the same class of no-KYC instant-swap service.

EXCLUDED — shared-financier hypothesis. Tested and ruled out. The Iranian operators (0x002E9EB3..., 0x73625B6c...) are funded by different upstream wallets (0xC43636B1..., 0x635DE420...). **No shared funding wallet exists between the clusters.** They share funding *typology* (no-KYC swaps) but not funding *infrastructure*; typology is non-discriminating and is carried at LOW, not as a link.

11. Attribution analysis (competing hypotheses)

The central question is what the shared builder (KJ-2) plus the disjoint funding (KJ-4) imply. Three hypotheses were weighed against the evidence.

H1 — Single actor operating both clusters. *Assessed unlikely.* Disjoint operator and funding wallets, distinct deployment cadences, and distinct hosting choices argue against one operator. The shared builder is explained more economically by H3.

H2 — Direct operational partnership (DPRK + Iran co-developing). *Assessed unlikely on current evidence, not excluded.* There is no on-chain coordination signal (no shared wallets, no cross-funding, no shared infrastructure beyond the common kit). Absence of an on-chain link is not proof of absence of off-chain coordination, hence "not excluded."

H3 — Shared toolkit / common MaaS builder, independently operated. *Assessed most likely.* Identical bytecode and the shared `StringChanged` topic across clusters, combined with eSentire's reported code overlap and Tsundere's Russian-speaking-MaaS characteristics, point to a common builder (probably Russian-speaking MaaS) whose EtherHiding resolver kit was adopted by both DPRK and Iranian operations. The disjoint funding and operation are exactly what H3 predicts.

Bottom line. The evidence supports **shared tooling with independent operation and financing** (H3). Claims of a unified actor (H1) or an operational partnership (H2) are **not supported** by the on-chain record. The "DPRK" and "Russian-speaking" labels on the two clusters remain single-/few-vendor and are carried at MODERATE.

12. Cross-cluster linkage — what it does and does not mean

The evidence supports	The evidence does support
A shared EtherHiding resolver builder/kit (HIGH)	A single actor operating both clusters
On-chain corroboration of EtherRAT ↔ Tsundere code overlap (HIGH)	A confirmed DPRK–Iran operational partnership
Co-hosting of both implants' C2 on one server (observed)	Shared operators or shared funding wallets
Russian-speaking MaaS as probable kit origin (MODERATE)	Attribution of either cluster beyond its single-/few-vendor basis

13. Intelligence gaps

- **Contract #3 calldata** is undecoded; it is the newest, most active contract and the likeliest source of additional live C2.
- **Host validation** for the four MODERATE domains (`rubysen.com` , `ager-stp.org` , `twicegrand.com` , `aabst one.com`) is pending; they remain MODERATE on calldata presence alone.
- **The builder's identity** (the presumed Russian-speaking MaaS author behind the shared kit) is not established here — only that a shared builder exists.
- **Off-chain coordination** between the clusters can be neither confirmed nor excluded from on-chain data.

- **EtherRAT → DPRK and Tsundere → koneko attributions** rest on limited vendor sourcing and are carried at MODERATE / MODERATE–HIGH respectively.

14. Outlook (1–3 months)

****Estimate 1 — Family expansion. *Likely (55–80%).***** The wallet-pivot method will surface additional Family A/B resolver contracts as operators deploy fresh ones. *Confirming indicator:* a new contract matching the `7d434425 / 7fcaf666` + `3ca6280d` + `1de57633...` fingerprint. *Falsifying indicator:* a sustained absence of new family contracts over the window.

****Estimate 2 — IP rotation, fingerprint persistence. *Highly likely (80–95%).***** Specific C2 IPs (including `91.215.85.42`) will rotate, but the `X-Bot-Server` server fingerprint and the `:3000 / :3001` co-hosting pattern will persist across rotations. *Confirming indicator:* new hosts presenting `X-Bot-Server` on `:3000`. *Falsifying indicator:* the implant drops the header or changes ports.

****Estimate 3 — Continued cross-cluster kit sharing. *Likely (55–80%).***** The shared builder will continue serving both DPRK and Iranian operations, with no merger of operation or funding. *Confirming indicator:* new contracts emitting `3ca6280d` funded by disjoint wallet clusters. *Falsifying indicator:* on-chain evidence of shared operator/funding wallets across clusters (would upgrade toward H2).

****Estimate 4 — Decoy/recycled-IP prevalence. *Roughly even to likely (45–80%).***** A meaningful fraction of newly decoded calldata entries will continue to be decoys or recycled co-tenant IPs rather than live C2. *Confirming indicator:* further decoded hosts that fail independent validation. *Implication:* the validation discipline in Section 9 should be treated as standing practice, not a one-off.

15. Detection and mitigation

Durable detection content (survives IP rotation) ships in `detections/` :

- **Suricata** (`etherrat_xbotserver.rules`) — fires on the `X-Bot-Server` response header and the bare-IP `:3000` beacon.
- **Sigma** (`etherrat_beacon.yml`) — outbound HTTP to a bare IP on `:3000` with no preceding DNS.
- **Sigma** (`etherhiding_rpc.yml`) — non-browser process contacting public Ethereum RPC endpoints (the C2-resolution step).
- **KQL + scan-hunt** (`hunting_queries.md`) — Defender/Sentinel queries plus Shodan/Censys banner hunts on the `X-Bot-Server` / `ETag` panel fingerprint.

Prioritize the server-side fingerprint over IP blocklists. The `X-Bot-Server` header and the panel `ETag` outlast any single C2 IP; an IP blocklist ages out within the rotation window (Estimate 2). For EtherHiding generally, monitor non-browser processes issuing `eth_call` to public RPC nodes — the resolution step is the one network behavior the technique cannot hide.

16. ATT&CK mapping

Technique	ID	Evidence
Web Service: Dead Drop Resolver	T1102.001	C2 address stored/retrieved via Ethereum contract storage
Application Layer Protocol: Web	T1071.001	HTTP beacon to <code>:3000</code> ; <code>X-Bot-Server</code> header
Non-Application Layer Protocol	T1095	Tsundere WebSocket C2 on <code>:3001</code>
Ingress Tool Transfer	T1105	Node.js runtime pulled from nodejs.org; payload staged
Exploitation for Initial Access	T1190	React2Shell (CVE-2025-55182) per Sysdig
Obfuscated Files or Information	T1027	Obfuscator.io-packed JS per Sysdig/eSentire
Proxy / disposable funding hops	T1090	single-use Nonce 0/1 intermediaries; SideShift terminus

Appendix A — Indicators

Machine-readable: `I0Cs/c2_hosts.csv` (hosts/domains/headers), `I0Cs/contracts.csv` (contracts, wallets, selectors, topics, build fingerprint), `I0Cs/excluded.csv` (ruled-out indicators). Supporting annexes: `analysis/contract_bytecode.md`, `analysis/funding_chain.md`.

Appendix B — Source reliability and methodology disclosure

- **On-chain** (contracts, wallets, calldata, topics): directly observed on Ethereum mainnet via read-only explorers — highest reliability; independently reproducible by any reader.
- **Host data** (`91.215.85.42`, `193.200.17.66`, `173.249.8.102`): third-party internet-scan and CT data (Shodan, Censys, crt.sh). Reliable as point-in-time observation; hosting attributions reflect scan time.
- **PCAP**: behavioral capture of a detonated sample; corroborates the scan-derived server fingerprint independently.
- **Vendor reporting** (Sysdig, eSentire, DFIR Report, Kaspersky, GTIG): used for attribution context and to mark PUBLISHED indicators. Attribution claims are carried at the confidence their sourcing supports and capped at MODERATE where single-vendor.
- **OPSEC**: passive, air-gapped. No connection was made to live C2. One page pull against `173.249.8.102` via a third-party request service is logged as an active touch and is not repeated.

License & citation

Indicators and detection content are released **TLP:CLEAR** for community defensive use. Confidence levels and estimative likelihoods follow ICD-203 and are the author's own. Please retain attribution when redistributing.

Wilson, Y. (2026). *EtherRAT On-Chain C2: A DPRK/Iran Shared-Builder EtherHiding Resolver Family, with Wire-Level C2 Confirmation*. TLP:CLEAR. github.com/yankywilson